



SERVER SIDE REQUEST FORGERY

Attacks and Mitigations

MEMBER

THY Dayuth
CHO Davon
KOSAL Karuna

Professor : **LAY Leangsros**

Date
March 27th, 2026



Table Content



INTRODUCTION



HOW SSRF WORKS



CHARACTERISTICS OR COMMON ATTACK PATHS



IMPACT



DEMONSTRATION



PREVENTION / MITIGATION





Introduction / Definition

> WHAT IS SSRF?

SSRF (Server-Side Request Forgery) is a vulnerability where an attacker tricks a server into making unintended requests.

> WHY "SERVER-SIDE"?

The request is executed by the backend server, not directly by the attacker.

> WHAT IS SSRF?

- Attacker → server → target
- The attacker does not access the target directly; the server does it for them.

> WHY IT MATTERS

- Internal systems trust requests from the server.
- Attackers can access resources they normally cannot.



How SSRF Works

> NORMAL REQUEST FLOW

- User → Web Application → External Resource (e.g., API, website)

> MALICIOUS REQUEST FLOW

The request is executed by the backend server, not directly by the attacker.

> TRUST BOUNDARY PROBLEM

- Internal systems trust requests from the server.
- Attackers can access resources they normally cannot.

> WHERE IS THE VULNERABILITY?

- Attacker → server → target
- The attacker does not access the target directly; the server does it for them.

> WHY SERVER BECOMES THE REQUESTER

- Internal systems trust requests from the server.
- Attackers can access resources they normally cannot.

> KEY POINT

- SSRF abuses the server's trust and access to reach hidden resources.

Characteristics / Common Attack Paths



01

Internal network access

- the server can reach private IPs or internal services.

02

Cloud metadata access

- cloud environments may expose sensitive instance information through special internal endpoints.

03

Bypassing intended restrictions

- the app may only expect external URLs, but the attacker supplies an internal one.

04

Different URL schemes

- some applications fail to restrict what type of resource can be requested.

Impact



DATA EXPOSURE

- internal files, service responses, or configuration data may be leaked.



UNAUTHORIZED INTERNAL ACCESS

- admin panels or internal APIs may be reached.



CREDENTIAL LEAKAGE

- secrets or tokens may be exposed.



ATTACK CHAINING

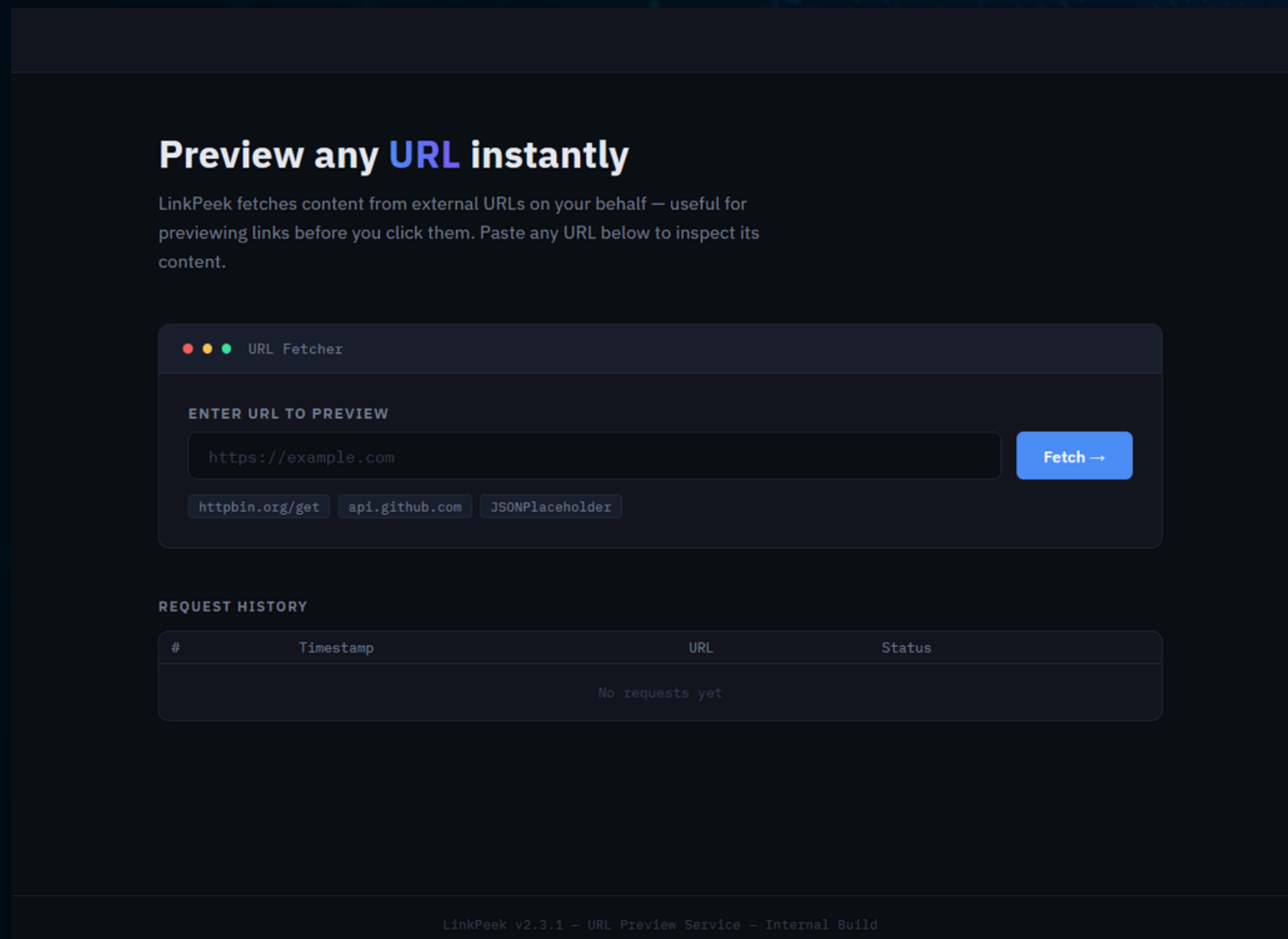
- SSRF can be used as a stepping stone for deeper compromise.



DEMONSTRATION

DEVICES IN USED

> WINDOW 11 (ATTACKER)



> DEBIAN (WEB SERVER)





DEMONSTRATION

NORMAL BEHAVIOR OF THE WEBSITE [VIDEO]



Secure Programming Presentation - Server-Side Request Forgery

dayuthdesuu



Watch on  YouTube



DEMONSTRATION VULNERABLE BEHAVIOR OF THE WEBSITE [VIDEO]



Secure Programming Presentation - Server-Side Request Forgery

dayuthdesuu



Watch on  YouTube



Prevention / Mitigation

01

Disable unused URL schemes

Allow only the schemes the app needs, usually `https://` and Block risky schemes like

- `file://`
- `ftp://`
- `gopher://`
- `dict://`

02

Validate and sanitize input

Never trust user input. Check it strictly and **reject** unexpected or malicious values.

03

Authenticate internal services

Protect internal services with proper authentication and authorization like

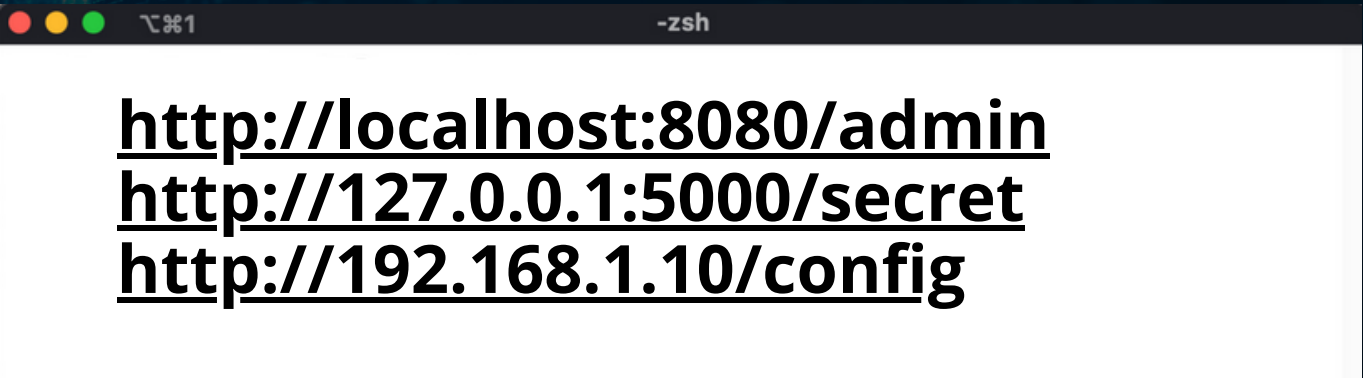
- MongoDB (Database)
- Elasticsearch (Search & analytics engine)
- Memcached (in-memory key-value store)

Security Measure

04

Allowlist + DNS check

Only allow approved **domains/IPs**. Validate and **restrict** user input to known safe targets.



```
-zsh
http://localhost:8080/admin
http://127.0.0.1:5000/secret
http://192.168.1.10/config
```

05

Safe response handling

Do not return raw backend responses. Filter and validate data before sending it to users.



References

OWASP Cheat Sheet (SSRF Prevention) : https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

Veracode : <https://info.veracode.com/rs/790-ZKW-291/images/ssrf-prevention-guide-en.pdf>

SSRF Bible Cheatsheet : https://cheatsheetseries.owasp.org/assets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet_SSRF_Bible.pdf

A New Era Of SSRF : <https://blackhat.com/docs/us-17/thursday/us-17-Tsai-A-New-Era-Of-SSRF-Exploiting-URL-Parser-In-Trending-Programming-Languages.pdf>





THANKS YOU

Q & A